

Plan de Respuesta a Incidente de Ransomware basado en NIST

Identificación

La situación ocurre cuando un empleado de TechCo recibió un correo electrónico de phishing, descargó el archivo y permitió a los atacantes instalar el ransomware en la red interna. Es por ello que procedí a la identificación de los activos críticos afectados, pudiendo identificar el servidor de archivos, la base de datos de clientes y el backup del sistema. Posiblemente comprometiendo el almacenamiento de documentos de uso diario, filtración de información sensible tanto personal, financiera como confidencial, la imposible recuperación de datos y el acceso a la misma red.

Analizando en profundidad estos posibles compromisos se ha podido ver que dentro del sistema hay falta de segmentación de red ya que hay ausencia de separación entre sistemas productivos y de respaldo por lo que el ransomware ha tenido tanto éxito, que hay ausencia de monitoreo en tiempo real ya que no saltó ninguna alerta temprana así como los sistemas de backup no estaban aislados ni asegurados. Otros factor ajeno al sistema es que los empleados no tenían capacitación es por ello que el phishing inicial fue efectivo

Protección

Para la correcta protección del sistema previa a un ataque es necesario tomar ciertas medidas preventivas como:

- La segmentación de red separando entornos críticos para contener ataques
 - Creando políticas de correo seguro implementando filtros antiphishing y sandboxing
 - Autenticación multifactor en accesos a sistemas críticos
 - Principio de mínimo privilegio limitando permisos de usuarios
 - Backups desconectados o en la nube con políticas de protección
 - Preparación del personal para su concientización e identificación de phishing y buenas prácticas
 - Actualización y parcheo continuo garantizando que todos los sistemas y aplicaciones estén reforzados
-

Detección

Los métodos y las herramientas que serían los más óptimos para la detección son:

- Tener un sistema SIEM para recopilar, gestionar y analizar los registros de eventos y detectar anomalías
 - También EDR para identificar comportamientos maliciosos en dispositivos y servidores
 - Realizar un monitoreo del tráfico de red con sistemas IPS para detectar actividad inusual
 - Tener alertas automáticas que identifiquen un incremento anormal en el cifrado de archivos o problemas de acceso
 - Realizar pruebas periódicas de detección, con simulaciones de incidentes y testear la efectividad de las herramientas implementadas
-

Respuesta

Si ocurriese un incidente de ransomware, los pasos de acción deberían ser los siguientes:

1. **Se debería activar el equipo de respuesta a incidentes (ERI)**

Dentro de este equipo deberían existir roles, teniendo a un líder de respuesta, un equipo técnico, uno encargado de las comunicaciones y finalmente, uno encargado del equipo de legal y gerencia.

Cuyos labores respectivamente serían coordinar la acciones, contener y erradicar el malware, manejar la información externa e interna y evaluar riesgos legales y decisiones estratégicas.

2. **Se debería proceder a una contención de forma inmediata**

Procedería la desconexión de los servidores afectados, aislar endpoints sospechosos, analizar puertos abiertos y bloquear comunicación con direcciones IP sospechosas o que parezcan maliciosas

3. **Continuar con la erradicación**

Una vez realizado los pasos anteriores, se debería eliminar el ransomware que esté en todos los sistemas comprometidos y revisar las posibles entradas. Además se deberían revisar posibles entradas de correo phishing o de posibles credenciales comprometidas

4. Comunicación

Una vez contenido el ataque se debería proceder a la notificación interna a los empleados además de añadir instrucciones claras de cómo evitarlo. Así mismo como una notificación externa a clientes y reguladores en caso de violación del GDPR

Es importante la transparencia con socios y partes interesadas para preservar confianza de la empresa

5. Documentación

Para evitar situaciones similares a futuro es importante registrar y recopilar toda la información y todos los pasos tomados, evidencia y tiempos de respuesta

Recuperación

Para restaurar las operaciones es necesario restablecer a los backups no comprometidos, verificar la integridad validando que los datos restaurados no contengan ningún código malicioso, aplicar el BCP estableciendo sistemas temporales y priorizar la recuperación de sistema crítico, ensayar la restauración para que sea de lo más eficiente y aplicar gran cantidad de refuerzos de controles post-incidente actualizando políticas y herramientas de seguridad

Mejora

Para poder evaluar métodos de mejora en el sistema es necesario tener una reunión de análisis para identificar los aspectos más fuertes y más débiles del sistema. Así como realizar métricas sobre cómo está funcionando el rendimiento, en su detección, la respuesta y el impacto económico.

Así mismo también se pueden realizar pruebas de simulación, revisión semestral del plan de respuesta y actualizarlo para tener en cuenta nuevas amenazas y capacitaciones y ejercicios para empleados

Conclusión

Como conclusión el ataque a TechCo ha podido demostrar las fallas que existen para la prevención de este tipo de ataques, el monitoreo en el sistema y la respuesta frente al ransomware. El NIST que se ha preparado proporciona la identificación de activos y vulnerabilidades, protección de controles técnicos, detección de amenazas con herramientas y respuesta con protocolos claros y roles definidos.

Todo esto permite no solo que se pueda prever que vuelva a ocurrir el incidente si no también recuperarlo y fortalecer su postura en seguridad